IFSP CAMPOS DO JORDÃO · ADS

Governança de TI

Quem decide, quem executa e quem responde

Aula 09

Prof. Geterson

Uma reunião de segunda-feira

- A equipe de TI quer migrar tudo para a nuvem este ano.
- O financeiro diz que não há orçamento para isso agora.
- O jurídico lembra que há dados de cliente envolvidos.
- O diretor pergunta: e quem decide isso?

Ninguém na sala sabe responder.

Duas coisas diferentes com nomes parecidos

Governança

Define a direção, aprova, estabelece limites e verifica se o combinado está sendo cumprido.

Gestão

Planeja, constrói, opera e monitora, dentro da direção que recebeu.

A governança define as regras do jogo. A gestão joga.

Os três verbos da governança

Avaliar	*Quais são os riscos desta iniciativa? Que valor ela entrega?*
Dirigir	*Aprovamos. Sigam por este caminho, com estas restrições.*
Monitorar	*O que foi aprovado está sendo cumprido e deu resultado?*

Note que nenhum dos três é executar. Governança não opera sistema.

A pergunta revela de que lado você está

Governança pergunta	Gestão pergunta
Devemos investir nisso?	Como implantamos isso?
Que risco estamos aceitando?	Como reduzimos esse risco?
Quem responde se der errado?	Quem faz cada parte?
Estamos obtendo o valor prometido?	O indicador está dentro da meta?

Confundir os dois lados é a origem de boa parte dos problemas que veremos agora.

Na reunião de segunda-feira, quem deveria decidir sobre a nuvem?

E se ninguém na empresa tem esse papel definido, quem acaba decidindo na prática?

Três casos reais

Vamos olhar três situações que deram muito errado.

- Em nenhuma delas o problema central foi a tecnologia.
- Em todas, alguém deixou de decidir, de verificar ou de responder.
- Sua tarefa, em cada caso: a falha foi de governança ou de gestão?

Caso 1 · INSS, vazamento de 2022

- Um incidente de segurança expôs dados pessoais sob responsabilidade do órgão.
- O INSS comunicou o incidente à ANPD, a Autoridade Nacional de Proteção de Dados.
- Mas resistiu a informar os titulares, as pessoas cujos dados foram expostos.

A LGPD, no artigo 48, exige a comunicação aos titulares.

INSS · o que realmente falhou

Em 2024, a ANPD condenou o órgão à sanção de publicização da infração.

O que foi punido não foi o vazamento

Foi a decisão sobre o que fazer depois dele. A resposta ao incidente é uma escolha, e alguém precisa ser dono dessa escolha.

A pergunta de governança

Existia uma política dizendo quem decide comunicar, em quanto tempo e para quem? Ou a decisão ficou solta?

Caso 2 · Post Office Horizon, Reino Unido

- O Horizon era o sistema de contabilidade usado nas agências dos correios britânicos, a partir de 1999.
- O sistema apresentava defeitos que geravam diferenças de caixa que não existiam de verdade.
- Diante das diferenças, a organização assumiu que os responsáveis pelas agências estavam furtando.

Perto de mil pessoas foram processadas e condenadas com base nesses dados.

Horizon · o que realmente falhou

O sistema foi tratado como infalível

A diferença de caixa virou prova de culpa. Ninguém investigou a hipótese de erro do próprio sistema.

Os alertas existiam e não subiram

O inquérito público concluiu que executivos do Post Office e da Fujitsu sabiam, ou deveriam saber, dos defeitos.

O custo

Condenações, prisões, falências e vidas destruídas ao longo de mais de uma década. Quase todas as condenações foram anuladas entre 2024 e 2025.

Caso 3 · Knight Capital, Estados Unidos, 2012

- Uma corretora que operava grande volume de ordens no mercado americano.
- A empresa colocou em produção uma atualização do software de negociação.
- A implantação foi feita sem os controles adequados de verificação.

O sistema começou a disparar ordens erradas assim que o mercado abriu.

Knight Capital · o que realmente falhou

Cerca de 45 minutos. Aproximadamente 440 milhões de dólares.

Não havia controle de mudança

Nenhuma verificação obrigatória antes de liberar a versão em produção, nem procedimento de retorno rápido ao estado anterior.

Ninguém tinha autoridade para parar

Enquanto as ordens erradas saíam, faltou um mecanismo claro de interrupção e uma pessoa com mandato para acionar.

Os três lado a lado

Caso	O que faltou	Governança ou gestão?
INSS	Decisão definida sobre como responder ao incidente	Governança
Horizon	Dever de investigar o próprio sistema e ouvir alertas	Governança
Knight Capital	Controle de mudança e autoridade para interromper	Os dois

Em nenhum dos três o software era o problema principal.

Faltou alguém decidir antes, e alguém verificar depois.

Nos três casos havia gente competente trabalhando. Por que isso não foi suficiente?

O que uma empresa precisaria ter no papel para que esses erros fossem menos prováveis?

O que é o COBIT 2019?

Framework de governança e gestão corporativa de TI — criado e mantido pela ISACA

- Manual de boas-práticas (em minha livre interpretação)
- Orienta organizações a criarem valor por meio da TI
- Equilibra benefícios, riscos e recursos tecnológicos
- Flexível, modular e integrável com outros frameworks
- Reconhecido globalmente como referência em governança de TI

Por que o COBIT 2019 é essencial hoje?

- TI deixou de ser suporte e tornou-se estratégica — decisões precisam de governança
- Maior flexibilidade e adaptação ao contexto de cada organização
- Integra-se com ITIL, ISO 27001, PMBOK e TOGAF sem conflito
- Atualizações contínuas pela ISACA — acompanha as mudanças do mercado
- Aplica-se a empresas de qualquer porte, setor e nível de maturidade digital

Como implementar o COBIT 2019

1. Avaliar o cenário atual
2. Definir o sistema de governança
3. Estabelecer políticas e responsabilidades
4. Executar de forma incremental
5. Monitorar e ajustar continuamente

Os 5 domínios do COBIT 2019

1 domínio de governança + 4 domínios de gestão — 40 objetivos no total

EDM	**Avaliar, Dirigir e Monitorar**	Governança **5 obj.**
APO	**Alinhar, Planejar e Organizar**	Gestão **14 obj.**
BAI	**Construir, Adquirir e Implementar**	Gestão **11 obj.**
DSS	**Entregar, Servir e Suportar**	Gestão **6 obj.**
MEA	**Monitorar, Avaliar e Analisar**	Gestão **4 obj.**

“Governança não é sobre fazer as coisas certas, é sobre garantir que sejam feitas.”

Formulação do professor, a partir da distinção adotada pelo COBIT 2019

Na próxima aula: os cinco domínios do COBIT 2019.